

**Автономная некоммерческая организация высшего образования  
«Университет Иннополис»**

**ВЫПУСКНАЯ КВАЛИФИКАЦИОННАЯ РАБОТА  
(БАКАЛАВРСКАЯ РАБОТА)  
по направлению подготовки  
09.03.01 «Информатика и вычислительная техника»**

**FINAL QUALIFICATION WORK  
(BACHELOR'S THESIS)  
Academic Program  
09.03.01 «Computer Science»**

**Направленность (профиль) образовательной программы  
«Информатика и вычислительная техника»**

**Field of Study:  
«Computer Science»**

**Тема**

**Среда выполнения OCI, ориентированная на безопасность:  
проектирование и сравнительная оценка с использованием  
изолированных сред выполнения**

**Topic**

**Security-First OCI Runtime: Design and Comparative Evaluation  
with Sandboxed Runtimes**

Работу выполнил /  
*Prepared by*

**Платонов Иван Васильевич**

подпись / signature

Руководитель  
выпускной  
квалификационной  
работы / *Final  
Qualification Work  
Supervisor*

**Садовых Андрей  
Александрович**

подпись / signature

Консультанты  
*Consultants*

**Салтанов Кирилл  
Сергеевич**

подпись / signature

Иннополис, Innopolis, 2026

# Оглавление

|   |                                            |   |
|---|--------------------------------------------|---|
| 1 | Введение . . . . .                         | 3 |
| 2 | Краткое содержание . . . . .               | 3 |
| 3 | Заключение . . . . .                       | 4 |
| 4 | Список использованной литературы . . . . . | 5 |

# 1 Введение

Выпускная квалификационная работа посвящена проектированию, реализации и оценке среды выполнения контейнеров OCI, ориентированной на безопасность. Актуальность темы определяется тем, что контейнеры разделяют ядро хоста, тогда как эталонный `runc` ориентирован на производительность, а не на изоляцию; `seccomp`, `AppArmor` и `capabilities` требуют ручной настройки, а песочницы `gVisor` и `Kata` дают сильную изоляцию ценой 20–100% накладных расходов. Операторы `plain runc` остаются без интегрированного инструмента автоматизации.

Цель — спроектировать и экспериментально оценить форк `runc`, генерирующий профили `seccomp`, `AppArmor` и `capabilities` из наблюдаемого поведения нагрузки одним флагом CLI. Объектом исследования является изоляция контейнерных процессов на Linux в рамках OCI; предметом — интегрированная runtime-локальная генерация профилей `confinement`. Научная новизна — объединение трёх механизмов ядра в двухфазный конвейер «сканирование — принудительное исполнение» с `cgroup-wide` трассировкой `capabilities` и самовыполняемыми OCI-хуками внутри бинарного файла runtime.

## 2 Краткое содержание

В основной части выполнен обзор литературы по контейнерной безопасности, изолированным runtime и автоматической генерации `seccomp`; сформулированы требования к сканеру (однофлаговый UX, три профиля за проход, совместимость с `upstream runc`, финализация без расширения привилегий) и модель угроз `post-exploitation` после компрометации приложения.

Независимо от режима сканирования форк меняет дефолт безопасно-

сти: `runc spec` генерирует пустой набор `capabilities`, а наборы `upstream` (3 `capabilities`) и `Docker` (14 `capabilities`) доступны через два взаимоисключающих флага. Режим `-security-scan` ослабляет `confinement` в памяти, устанавливает хуки, запускает контейнер, останавливает трассировщики и сужает `config.json`; `seccomp` записывается через runtime-трассировку `syscalls`, `capabilities` — через `eBPF` по `cgroup v2`, `AppArmor` обучается в `complain mode`. Хуки реализованы подкомандами `runc`; `OCI bundle` не получает исполняемых артефактов.

На стенде `runc-hardened-test` (Ubuntu 24.04, уязвимое Flask-приложение) один проход `-security-scan` формирует `seccomp.json`, профиль `AppArmor` и журнал `capabilities`. После `scan-then-enforce reconnaissance`, чтение `/etc/shadow`, `reverse shell` и `mount probe` блокируются `enforced seccomp`; `ping` и `upload` календаря сохраняются. Ограничения: покрытие равно пройденным путям; `file capabilities` не попадают в `trace`.

## 3 Заключение

Разработан и экспериментально оценён `security-first` форк `OCI runtime runc`: пустой набор `capabilities` по умолчанию с двумя `opt-in` флагами, флаг `-security-scan` для генерации профилей `seccomp`, `AppArmor` и `capabilities`, сужение `config.json` без расширения привилегий. Конвейер существенно улучшает `post-exploitation containment` относительно `stock runc` на тестируемой нагрузке при сохранении легитимного поведения; выводы ограничены одним `web-workload` и качественными метриками.

## 4 Список использованной литературы

- [1] X. Wang и D. Johannesson, “Performance and isolation analysis of RunC, gVisor and Kata Containers runtimes,” *Cluster Computing*, т. 25, с. 2363—2380, 2022. DOI: 10.1007/s10586-021-03517-8.
- [2] S. Volpert, S. Winkelhofer, S. Wesner и J. Domaschka, “An Empirical Analysis of Common OCI Runtimes’ Performance Isolation Capabilities,” в *Proceedings of the 15th ACM/SPEC International Conference on Performance Engineering*, ACM, 2024, с. 60—70. DOI: 10.1145/3629526.3645044.
- [3] W. Viktorsson, C. Klein и J. Tordsson, “Security-Performance Trade-offs of Kubernetes Container Runtimes,” в *2020 IEEE MASCOTS*, IEEE, 2020, с. 1—4.
- [4] N. Lopes, R. Martins, M. E. Correia, S. Serrano и F. Nunes, “Container Hardening Through Automated Seccomp Profiling,” в *Proceedings of the 6th International Workshop on Container Technologies and Container Clouds*, ACM, 2020, с. 31—36. DOI: 10.1145/3429885.3429966.
- [5] M. Mattetti и Y. Allouche, “Automatic security hardening and protection of linux containers,” *Security and Privacy in Communication Systems*, 2020.
- [6] M. Reeves, D. J. Tian, A. Bianchi и Z. B. Celik, “Towards Improving Container Security by Preventing Runtime Escapes,” в *2021 IEEE Secure Development Conference (SecDev)*, IEEE, 2021, с. 38—46.